

google-marketing-gateway

Google Ads API Basic Access - Tool Design and Security Controls

Application owner: Konjac Note

Primary website: <https://konjac-note.com/>

Repository: <https://github.com/tacogips/google-marketing-gateway>

Document date: 2026-08-16

1. Executive Summary

google-marketing-gateway is a Swift 6 command-line tool for an internal operator to manage the organization's own Google marketing resources through official Google APIs. The tool is not a hosted multi-tenant service, does not resell Google Ads access, and does not expose a generic proxy. Every implemented action maps to a fixed, typed, reviewed API operation.

Basic Access is requested so the organization can use its manager account for supported manager-client administration and operate its own production Google Ads accounts through the gateway. The intended audience is internal employees and authorized contractors only.

2. Business Model and Intended Use

- Konjac Note develops and operates software products and related engineering services.
- The gateway automates reporting, Keyword Planning, controlled campaign creation, account hierarchy reads, and reviewed client-account administration for owned accounts.
- No third-party ad accounts are onboarded without explicit authorization, and no API data is sold or used for unrelated profiling.
- The tool is operated locally from a command line by authenticated internal personnel.

3. Architecture

Component	Responsibility
Reader executable	GAQL reads, accessible customers, hierarchy, users, Keyword Planning, reports, and status verification. It cannot mutate resources.
Writer executable	Allowlisted typed creation and reversible non-administrative writes. Campaign creation uses validate-only before apply and exact customer confirmation.
Deleter executable	The only executable capable of emitting Google Ads remove operations. Removal targets and resource names require explicit confirmation.
Admin executable	Manager-client linking and confirmed client-account creation. Campaign and ad mutations are unavailable here.
Shared core	Strict JSON decoding, profile capability checks, input bounds, fixed Google origins, credential redaction, and injected HTTP transport.

4. Authentication and Authorization

- OAuth uses the official <https://www.googleapis.com/auth/adwords> scope.
- Access tokens, refresh tokens, OAuth client secrets, and the developer token are never committed to the repository or embedded in profiles.
- Secrets are supplied at runtime from kinko-managed environment variables; configuration contains only environment-variable names.
- The login customer ID is also resolved from a validated environment-variable reference. Customer IDs must contain only ASCII digits and are bounded to 20 characters.
- Profile capability, executable mode, and operation-catalog capability must all match before credentials are resolved.

5. Request and Spend Safety

- Google API origins and API versions are fixed in code. Callers cannot provide arbitrary URLs, headers, or HTTP methods.
- Campaign inputs use a closed JSON schema with bounded names, counts, HTTPS final URLs, geographic/language identifiers, bids, and budgets.
- Campaign and ad creation is sent as one atomic `GoogleAdsService.Mutate` request with `partialFailure=false`.
- The same request must pass `Google validateOnly` before `apply`. `Apply` requires an exact target customer confirmation.
- Local hard caps limit both daily budget and CPC bid. Operators additionally review aggregate account budgets before creation.
- New Search campaigns explicitly declare EU political advertising status and create the required budget, campaign, criteria, ad group, keywords, and responsive ad resources.
- Keyword ideas use a typed read request: one language, one to ten geo targets, up to twenty seed phrases, an optional HTTPS URL, and a response page size capped at 1,000.

6. Deletion and Administrative Boundaries

- Reader, writer, and admin executables cannot emit provider remove operations.
- Only the dedicated deleter builds remove requests; each `apply` requires the full resource name as confirmation.
- Manager-client linking is restricted to the admin executable. The flow creates a pending `CustomerClientLink`, resolves its manager link ID, and accepts it from the client account.
- Client-account creation is restricted to the admin executable, uses a typed `name/currency/time-zone` request, and requires exact manager confirmation. Because `CreateCustomerClient` has no `validateOnly` mode, its plan is strictly local and zero-network.
- Operators apply client-account creation only when the manager satisfies Google's eligibility requirements, including the documented spend and policy-standing conditions.
- Administrative and destructive operations are unavailable through any generic passthrough endpoint.

7. Data Handling

- The gateway processes Google Ads API JSON responses in the invoking process and writes them to standard output for the authorized operator.
- It does not run a shared database, cross-customer data warehouse, public API, or background data broker.
- OAuth token stores, when used, are local private files with path-collision, permission, and symlink protections.
- Errors are sanitized to structured provider status and allowlisted Google Ads error codes; credentials and raw sensitive payloads are not echoed.

8. Implemented Google Ads Operations

Capability	Operation	Provider method
Reader	Accessible customer discovery	CustomerService.ListAccessibleCustomers
Reader	Bounded GAQL and generated hierarchy/user reads	GoogleAdsService.Search
Reader	Keyword ideas with bounded keyword/URL seeds	KeywordPlanIdeaService.GenerateKeywordIdeas
Writer	Atomic Search campaign and responsive ad creation	GoogleAdsService.Mutate
Admin	Manager-client invitation and acceptance	CustomerClientLinkService / CustomerManagerLinkService mutate
Admin	Confirmed client-account creation under the manager	CustomerService.CreateCustomerClient
Deleter	Reviewed campaign, budget, criterion, ad group, keyword, and ad removal	Resource-specific mutate remove

9. Testing and Operational Verification

- The SwiftPM test suite covers request wire shapes, Keyword Planning seed selection, client-account creation, binary capability isolation, strict credential profiles, confirmation gates, fixed origins, provider error redaction, and zero-network plan behavior.
- SwiftLint and SwiftPM build/test tasks run before release or operational handoff.
- Live production actions use plan, provider validate-only, apply, and read-back verification stages.

10. Incident Response and Change Management

- Credential values can be revoked or rotated independently without modifying repository configuration.
- The operation catalog defaults unimplemented and restricted methods to unavailable; new mutates require typed implementation and tests.
- Suspicious or unintended spend is handled by pausing campaigns in Google Ads, revoking runtime credentials, and reviewing account change history.
- Source changes are version controlled in the public repository and reviewed with deterministic tests.

11. Contact

API contact: me@tacogips.me

Website: <https://konjac-note.com/>

Manager account: 382-700-4490